

Merbau Group: Izin Consent and Preference Service

Detailed Design

Architecture, requirements, and validation criteria for build

Version	1.1
Status	Design phase, build not started
Last updated	2026-10-02 (review revisions) · previous 1.0 of 2026-09-24
Prepared by	Merbau Digital, Customer Data Platforms Team
Companion documents	Izin Conceptual Design v0.8; Group Purpose Register GPR-3; Data Protection Impact Assessment DPIA-2026-11 (draft); Partner Programme Commercial Terms 2026

Revision history

Version	Date	Changes
1.0	2026-09-24	First consolidated detailed design.
1.1	2026-10-02	Post-review revisions: FR-9; topic key (14.2, DEC-02); DNC result validity and refresh cycle (16, DEC-06); receipt links and receipt page (17); Eligibility API capacity (24.2, NFR-8); receipt storage (24.3); migration of customers with no recorded preference (25, DEC-11); acceptance criteria for FR-9, NFR-2 and NFR-8 (28).

Changes since version 1.0

This version updates the sections listed below after the design review of 2026-09-29. Sections not listed are unchanged from version 1.0.

- FR-9 and Section 17: when receipts are sent, the receipt link and what the receipt page shows.
- Section 14.2 and DEC-02: the key of the consent .changes topic.
- Section 16 and DEC-06: validity of DNC Registry results, the refresh cycle and the handling of results awaiting refresh.
- Section 24.2 and NFR-8: campaign load on the Eligibility API and its provisioned rate.
- Section 24.3: storage for receipts.
- Section 25 and DEC-11: migration of customers with no recorded preference in the legacy systems.
- Section 28: acceptance criteria for FR-9, NFR-2 and NFR-8.

Table of Contents

1. Purpose and Scope
2. Requirements
3. Foundational Principles
4. Business Units, Channels and Partners
5. Regulatory Basis
6. Target Architecture
7. Purpose Catalogue and Notice Versioning
8. Identity and Contact Points
9. Consent Record Model
10. Capture in Web and App
11. Capture in the Contact Centre and Stores
12. Capture in Partner Channels
13. Withdrawal Semantics
14. Event Bus and Change Propagation
15. Downstream Consumers
16. Do Not Call Registry Checks

- 17. Consent Receipts
 - 18. Data Model
 - 19. Retention and Archival
 - 20. Regulator Audit and Evidence Export
 - 21. Security and Access Control
 - 22. Data Residency and Partner Data Sharing
 - 23. Resilience and Disaster Recovery
 - 24. Latency and Capacity Budget
 - 25. Migration from Legacy Systems
 - 26. Confirmed Decisions
 - 27. Pending Backlog
 - 28. Validation and Acceptance Criteria
 - 29. Implementation Readiness Assessment
 - 30. Build Phases
-

1. Purpose and Scope

This document describes the architecture of Izin, the Merbau Group consent and preference service (CPS). Izin records what every Merbau customer has agreed to, for which purpose, through which channel and under which notice, and it tells every system that contacts customers or uses their data whether it may do so. It is written to a level of technical detail sufficient for an engineering team to begin implementation. Section 29 gives an explicit assessment of where that is and is not yet true.

Today each business unit keeps its own marketing flags: the telco CRM has three opt-out columns, the Rewards platform has one newsletter flag, and store sign-ups are recorded on paper forms that are scanned and keyed in by a vendor. A customer who withdraws in one place is still contacted from another, and the Office of the Data Protection Officer (ODPO) cannot show a regulator when or how any given consent was obtained. Izin replaces these flags with one purpose-based consent record per customer, one capture API for every channel, and one stream of consent changes that every downstream system applies.

In scope

Consent capture for every Merbau channel (web, mobile app, contact centre, stores and partner channels); the purpose catalogue and notice versions; the consent record and its history; withdrawal; propagation of consent changes to downstream marketing, analytics, CRM and partner systems; the eligibility API that answers "may we contact this person for this purpose through this channel"; Do Not Call (DNC) Registry checks for Singapore telephone numbers; consent receipts; retention; the regulator evidence export; and migration of the legacy flags.

Out of scope

The marketing campaign platform itself (Kempen, which consumes Izin); customer identity and authentication, which remain with Merbau ID; consent for cookies and web tracking, which the web team manages with its own banner and a separate design; and access and correction requests under the PDPA, which the ODPO handles through its case tool and which read from Izin through the regulator export in Section 20.

Volume baseline

Metric	2026 actual	Design target (2028)
Customer profiles with a Merbau ID	8.1 million	8.7 million
Active mobile lines (Merbau Mobile)	5.6 million	6.2 million
Fibre broadband accounts (Merbau Fibre)	0.9 million	1.1 million
Merbau Rewards members	4.1 million	4.8 million
Consent changes per day (average)	95,000	140,000
Consent changes per second (peak, campaign reply surge)	60	120
Marketing messages sent per month	31 million	40 million

2. Requirements

Every requirement below has a validation method and acceptance criterion in Section 28.

2.1 Functional Requirements

ID	Requirement
FR-1	Capture consent and withdrawal per purpose from web, app, contact centre, stores and partner channels through one Consent API.
FR-2	Record a consent as granted only from an affirmative act of the customer for that specific purpose; never from silence, inactivity or a pre-selected option.
FR-3	Record for every change the channel, the actor (customer, contact centre agent, store staff, partner), the notice version shown, the time, and an evidence reference (session, call recording or signed form).
FR-4	Offer withdrawal in every channel where consent can be given, with no more steps than granting.
FR-5	Publish every consent change to downstream consumers through the event bus.
FR-6	Provide an Eligibility API that answers whether a customer or contact point may be contacted for a purpose through a channel, combining consent state and DNC status.
FR-7	Check every Singapore telephone number against the DNC Registry before a marketing SMS or call is sent to it, unless the holder's clear and unambiguous consent is held in evidential form.
FR-8	Provide a preference centre in web and app that shows every purpose, its current state and the notice text, and lets the customer change any of them.
FR-9	Send the customer a consent receipt for every consent change, within five minutes of the change, by SMS to the mobile number on the profile or by email where the customer has no mobile number.
FR-10	Let approved partners capture consent for Merbau purposes in their own channels through the Partner Consent API, and supply partners with the consent state for the partner-sharing purposes.
FR-11	Produce, on request of the ODPO, an evidence export for a customer, a purpose or a time range (Section 20).
FR-12	Treat an SMS reply of STOP to a Merbau marketing short code, and the opt-out option of the marketing IVR, as a withdrawal of the matching purpose.
FR-13	Migrate the marketing preferences held in the legacy systems into Izin before the legacy flags are retired.
FR-14	Provide the ODPO with a console to manage purposes, notice versions and partner registrations.

2.2 Non-Functional Requirements

ID	Requirement
NFR-1	Consent API p99 latency of 300 ms or less for a single change at the design-target peak.
NFR-2	A withdrawal recorded in any channel is applied by every internal downstream consumer (Kempen, Group Analytics Platform, contact centre CRM and Rewards platform) within 24 hours, and is included in the next nightly partner file for the partner concerned.
NFR-3	Availability of the Consent API and Eligibility API of 99.95% per calendar month.
NFR-4	No consent change acknowledged to a channel is lost on the failure of a node or an availability zone (RPO 0); objectives for the loss of the region are set in Section 23.2.
NFR-5	For every consent in force, Izin can produce the evidence of how, when, through which channel and under which notice version it was given, with the full history of changes to it, within five business days of a request.
NFR-6	Personal data encrypted in transit and at rest; access on least privilege; every staff read of a customer record logged.
NFR-7	All Izin data stores reside in Singapore (AWS ap-southeast-1).
NFR-8	The Eligibility API sustains the design-target campaign peak of 1,000 requests per second with p99 latency of 50 ms or less.
NFR-9	No marketing SMS or call is made to a Singapore telephone number without either a valid DNC Registry result showing it is not registered, or clear and unambiguous consent held in evidential form.

3. Foundational Principles

These principles govern every component in this document. Where a section has to trade them off, it says so.

1. **P1 Purpose-specific.** Consent is held per customer (or per contact point, Section 8) per purpose. There is no general "marketing" flag.
2. **P2 Affirmative act only.** A consent is recorded as granted only when the customer has taken a positive action for that purpose. Silence, inactivity, a pre-ticked box or acceptance of terms and conditions is never consent.

3. **P3 The event log is the system of record.** Every change is an immutable consent event. The current state is a projection of the events and can be rebuilt from them.
4. **P4 Withdrawal is never harder than granting.** A withdrawal takes effect in Izin at once and is answered by the Eligibility API on the next read.
5. **P5 Fail closed.** When consent or DNC status cannot be determined, the answer is "do not contact".
6. **P6 One truth.** Downstream systems keep no consent truth of their own; they apply Izin events or call the Eligibility API.
7. **P7 Minimum data.** Izin holds only the personal data needed to identify a customer and the contact points consents attach to.
8. **P8 Singapore resident.** Izin data stays in Singapore.

4. Business Units, Channels and Partners

Business unit	Customers	Capture channels	Marketing channels
Merbau Mobile	5.6 million active lines	App, web, contact centre, stores, SMS keyword	SMS, voice, email, app push
Merbau Fibre	0.9 million accounts	Web, contact centre, installer tablet (via the stores flow)	Email, voice
Merbau Stores	61 stores, about 2.3 million identified buyers a year	Point-of-sale tablet, web	Email, SMS
Merbau Rewards	4.1 million members	App, web, stores	App push, email, SMS

Merbau Mobile allocates numbers from its own number ranges. A terminated mobile number is quarantined for six months and then returned to the pool for allocation to new subscribers.

Two partners take part in the 2027 partner programme:

- **Seri Assurance Berhad**, an insurer headquartered in Kuala Lumpur, offers device and travel insurance to Merbau customers who agree to purpose PTN-INS. Seri sells through its own app and its Kuala Lumpur contact centre.
- **Lintang Bank**, a Singapore bank, issues the Merbau Rewards co-brand credit card to customers who agree to purpose PTN-CARD.

The contact centre (about 900 agents across two sites in Singapore and one outsourced site) handles service calls and outbound telemarketing for all business units on one contact-centre platform with call recording.

5. Regulatory Basis

Izin is designed against the Personal Data Protection Act 2012 (PDPA) as amended in 2020, and the Commission's advisory guidelines. The provisions that shape the design are:

Provision	What it requires	Where Izin addresses it
Consent Obligation (s13, s14)	Consent for a purpose, given after notification; consent may not be made a condition of a product beyond what is reasonable	Sections 7, 10
Notification Obligation (s20)	Purposes notified on or before collection	Section 7
Withdrawal of consent (s16)	Withdrawal on reasonable notice; the organisation informs the individual of the likely consequences and ceases use	Section 13
DNC provisions (Part 9)	Check with the DNC Registry before sending a specified message to a Singapore telephone number, unless clear and unambiguous consent in evidential form is held; give effect to withdrawal of that consent	Sections 13, 16
Accountability (s11, s12)	Policies, practices and the ability to demonstrate compliance	Sections 19, 20
Protection Obligation (s24)	Reasonable security arrangements	Section 21

Service messages (bill reminders, outage notices, order and delivery updates) are not specified messages under the

Eighth Schedule and are not consent-based; Izin records them under purpose SVC-NOTICE with basis CONTRACT so that the catalogue is complete, and they are not subject to withdrawal.

6. Target Architecture

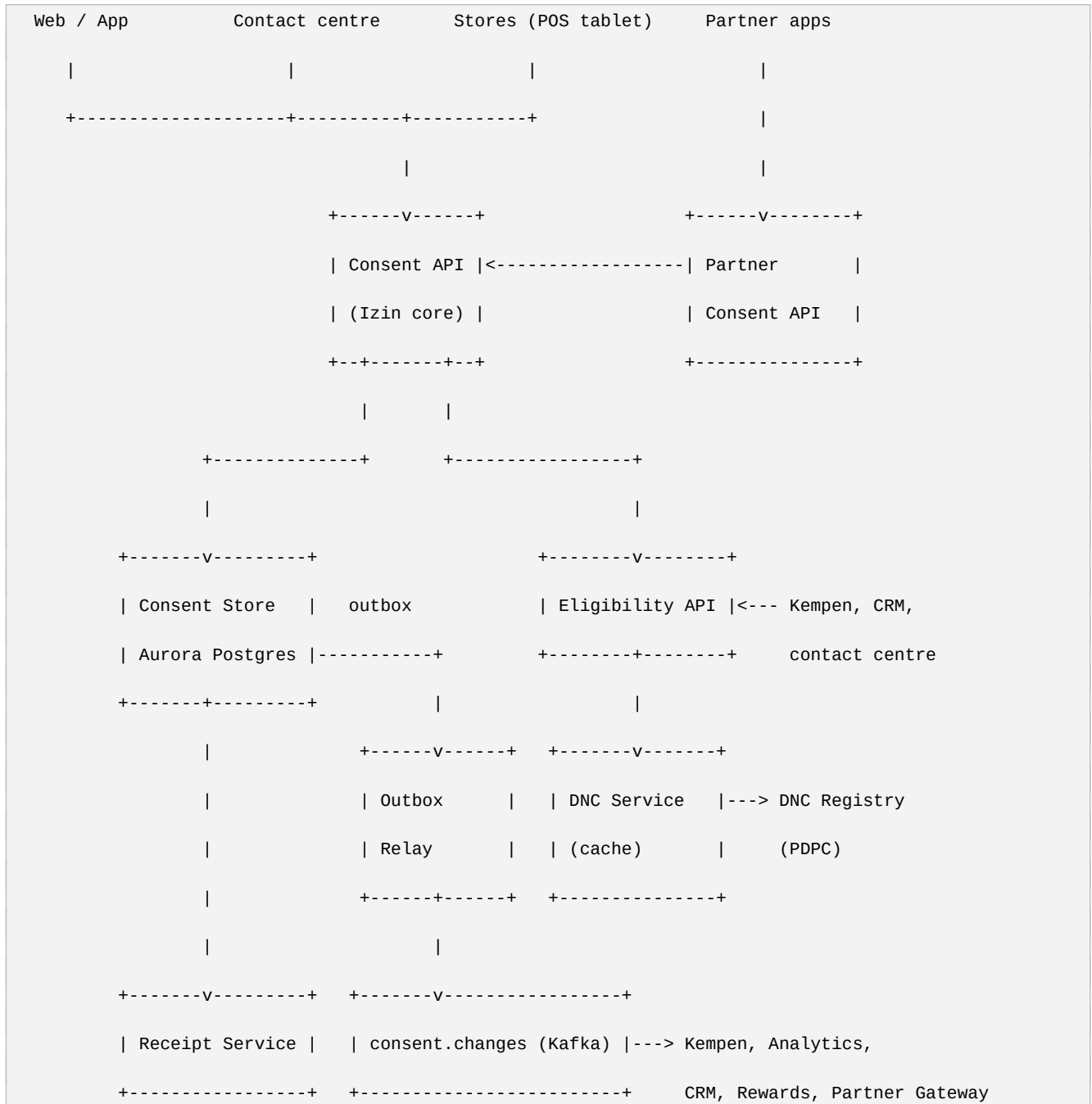


Figure 1. Izin components. All components run in AWS ap-southeast-1.

Layer responsibilities

Component	Responsibility
Consent API	Accepts consent changes from first-party channels, validates them against the purpose catalogue, writes event, state and outbox rows in one transaction, returns the new state and receipt number.
Partner Consent API	Accepts consent changes from registered partners (Section 12) and forwards them to the Consent API with the partner as actor.
Consent Store	Aurora PostgreSQL 16 cluster holding events, state, contact points, purposes, notices, receipts and the outbox.

Component	Responsibility
Outbox Relay	Publishes outbox rows to the consent . changes topic (Section 14).
Eligibility API	Answers contact decisions from consent state and the DNC cache.
DNC Service	Keeps DNC Registry results for every Singapore number in the marketing base (Section 16).
Receipt Service	Issues consent receipts by SMS or email (Section 17).
Partner Gateway	Builds the nightly partner files from the event stream (Section 15).
ODPO Console	Purpose and notice management, partner registry, evidence export (Section 20).

Izin runs on Amazon EKS in the group's shared-services account, with the Consent Store on Aurora PostgreSQL and the event bus on Amazon MSK (Kafka).

7. Purpose Catalogue and Notice Versioning

The purpose catalogue is the single list of reasons for which Merbau collects, uses or discloses personal data that Izin governs. The ODPO owns it through the ODPO Console.

Code	Purpose	Basis	Contact channel
MKT-SMS	Marketing of Merbau products and offers by SMS	Consent	SMS
MKT-VOICE	Marketing of Merbau products and offers by telephone call	Consent	Voice
MKT-EMAIL	Marketing of Merbau products and offers by email	Consent	Email
MKT-PUSH	Marketing by app push notification and in-app message	Consent	Push
PRS-OFFERS	Use of usage and purchase history to personalise offers across business units	Consent	None
PTN-INS	Disclosure of name, mobile number, email and Rewards tier to Seri Assurance for insurance offers	Consent	Partner
PTN-CARD	Disclosure of name, mobile number, email and Rewards tier to Lintang Bank for co-brand card offers	Consent	Partner
SVC-NOTICE	Service and account messages	Contract	All
LGL-REG	Subscriber registration records kept under telecommunications regulation	Legal obligation	None

Each purpose has a series of notice versions. A notice version holds the exact customer-facing text in English, Chinese, Malay and Tamil, an effective date and a materiality flag set by the ODPO. A material change (a new category of data, a new recipient, a new channel) creates a new purpose version, and existing consents for the old version are not carried over: the customer is asked again, and until they answer, the purpose is treated as not granted. A non-material change (wording, translation, layout) creates a new notice version under the same purpose version, and existing consents remain valid. Every consent event records the purpose version and notice version that the customer saw, so the evidence export can show the exact text.

Purpose codes are never reused. A retired purpose keeps its history and its events, but the Consent API rejects new grants for it.

8. Identity and Contact Points

A customer is identified by their Merbau ID subject (`mid`, a UUID issued by the group identity provider over OIDC). Online channels always carry the `mid` of the signed-in customer. The contact centre and stores look the customer up by mobile number or email and confirm identity with a one-time code sent to the registered mobile number before any change is recorded.

A contact point is a channel address: a Singapore telephone number, an email account or an app installation. Consents for the purposes MKT-SMS and MKT-VOICE are held per contact point, because the DNC provisions apply per Singapore telephone number and because a customer may have several lines (family plans average 2.3 lines per account holder). Consents for the other purposes are held per customer.

The `contact_point` table links each contact point to the `mid` that owns it. When a mobile line is terminated, the consents held on its number remain on the contact point record, which keeps the history of the number complete for audit.

Inbound withdrawals that carry only a number (a STOP reply, the IVR opt-out) are applied to the contact point for that number, so they take effect even when the caller cannot be matched to a Merbau ID.

9. Consent Record Model

Izin stores consent as an append-only sequence of events per subject and purpose, where the subject is either a customer (`mid`) or a contact point. Each event has:

- `event_id` (UUID v7) and `subject_type`, `subject_id`, `purpose_code`, `purpose_version`;
- `state` (`GRANTED`, `WITHDRAWN` OR `NOT_RECORDED`) and `basis`;
- `seq`, the per-subject-and-purpose sequence number, starting at 1;
- `channel`, `actor_type`, `actor_id`, `notice_version`, `evidence_ref` and `captured_at`;
- `idempotency_key`, supplied by the channel.

The Consent API writes a change in one database transaction: it reads the current `consent_state` row with `SELECT ... FOR UPDATE`, checks that the request's `expected_seq` (if supplied) matches, inserts the event with `seq + 1`, updates the state row, and inserts an outbox row. A unique constraint on (`subject_type`, `subject_id`, `purpose_code`, `seq`) makes a lost update impossible even if two channels race, and a unique constraint on (`actor_type`, `idempotency_key`) makes a retried request return the original result without a second event. Because event, state and outbox are written in one transaction, there is no dual write: a change is either fully recorded and queued for publication or not recorded at all.

`consent_state` is a projection and can be rebuilt from events by replaying them in `seq` order. A nightly job recomputes the state of a 1% random sample of subjects from their events and alerts on any difference; a full rebuild of the 8.7 million customers takes about 40 minutes on a reader instance and is run before each release that touches the projection.

A withdrawal does not delete anything: it is an event with state `WITHDRAWN`, and data use for that purpose stops. What is kept and for how long is set by Section 19, not by the state of a consent.

10. Capture in Web and App

The web preference centre and the app's Privacy and Preferences screen are the same component, served by the Consent API and rendered from the purpose catalogue.

- Each consent purpose is shown on its own row, with a short statement, a link to the full notice version, and a toggle that is off until the customer turns it on. There is no "select all" control.
- Consent for any marketing or partner purpose is never a condition of signing up, buying a plan or joining Rewards; the sign-up flows complete with every toggle off.
- The notice text shown is the current notice version for the customer's language; the version ID is posted with the change, and the API rejects a preference-centre change that names a notice version which is not current for that purpose.
- Every change is sent with an idempotency key generated when the screen is opened, so a double tap or a network retry records one event. The app or web session ID and the screen release are recorded as `evidence_ref`.
- After a change, the screen re-reads state from the API and shows the time of the change and the receipt number.

Sign-up forms in the app and on the web place the marketing toggles after the account details, under the heading "Would you like to hear from us?", with each toggle naming its channel. A customer who does nothing is recorded with no event at all for those purposes, and the Eligibility API treats an absent state as not granted.

11. Capture in the Contact Centre and Stores

Contact centre agents and store staff use the Izin panel embedded in the contact-centre CRM and the point-of-sale tablet. The panel shows the same purposes as the preference centre. The agent reads the scripted notice for the purpose (the script is the notice version text), the customer answers, and the agent records the answer. The panel attaches the call recording ID (contact centre) or the signed-tablet form ID (stores) as `evidence_ref`, and the customer's one-time code confirmation from Section 8 is stored with the event.

Stores without connectivity at the time of sign-up (pop-up counters and roadshows) capture consent on the tablet offline, with the customer's signature on the tablet form as evidence in place of the one-time code; the tablet queues the changes with their original `captured_at` and idempotency keys and submits them when connectivity returns. Queued changes are submitted in the order captured, and the Consent API accepts them with the notice version that was current at their `captured_at`.

Outbound telemarketing calls end with the agent offering the customer the option to stop marketing calls. A request to stop is recorded as a withdrawal of MKT-VOICE on the number called, during the call.

12. Capture in Partner Channels

Registered partners call the Partner Consent API, which accepts grants and withdrawals for the partner-sharing purposes and, for Seri Assurance, also for MKT-EMAIL, because Seri's insurance sign-up journey asks customers whether they also want Merbau offers by email. The partner authenticates with mutual TLS using a client certificate issued by the Merbau partner CA, and each request is signed with the partner's private key. A partner can submit changes only for the purposes listed against it in the partner registry.

A partner identifies the customer by mobile number and date of birth. The Partner Consent API resolves these to a `mid`; if no single match is found, the change is rejected and the partner is told to direct the customer to the Merbau app. The customer confirms each change with a one-time code that Merbau sends to the registered mobile number and that the customer enters in the partner's app. Partner-captured events carry `actor_type = PARTNER` and the partner's own reference as `evidence_ref`.

Partners receive the consent state for their own partner-sharing purpose through the nightly partner file (Section 15).

13. Withdrawal Semantics

A withdrawal is accepted in every channel that accepts a grant: preference centre, app, contact centre, stores, partner API, STOP reply and IVR opt-out. It is recorded in the same transaction model as a grant, and the next Eligibility API call for that subject and purpose returns "do not contact", because the Eligibility API reads consent state from the Aurora writer endpoint, not from a reader.

Before the customer confirms a withdrawal in the preference centre, the screen states the likely consequence (for example, "You will stop receiving Rewards double-points offers by SMS"), as section 16 of the PDPA requires. The withdrawal is never refused and never delayed by the consequence notice.

Withdrawal stops the use of personal data for that purpose. It does not stop service messages under SVC-NOTICE, which are not consent-based, and it does not delete the customer's data; retention is governed by Section 19. Withdrawal of MKT-SMS or MKT-VOICE on a number also ends the evidential-consent exemption for that number, so from that moment the DNC Registry result decides whether any later marketing to the number is allowed, until the customer grants again.

Campaigns already queued in Kempen re-check eligibility per recipient at send time (Section 15), so a withdrawal recorded minutes before a send stops that send.

14. Event Bus and Change Propagation

14.1 Outbox

Every consent change inserts an outbox row in the same transaction as the event (Section 9). The Outbox Relay, a single active pod with a standby, reads unpublished rows in `outbox_id` order in batches of 500 and publishes them to Kafka with `acks=all` and an idempotent producer. It marks a row published only after the broker acknowledges it.

14.2 Topic

Consent changes are published to the topic `consent.changes` on the group's Merbau Data Hub MSK cluster (three

brokers across three availability zones, replication factor 3, `min.insync.replicas 2`). The topic has 24 partitions and is keyed by subject and purpose (`subject_id:purpose_code`), with `cleanup.policy=compact`, `segment.ms` of one hour and `min.compaction.lag.ms` of one hour, so the topic keeps the latest event for every subject and purpose indefinitely and a new consumer can bootstrap from it without a database extract. For a contact point, the subject is the contact point ID. The Merbau Data Hub cluster is shared by the group's data products. Any service holding a client certificate issued by the Data Hub certificate authority can consume any topic on it, which keeps onboarding of new consumers to a single certificate request.

14.3 Event payload

Each event describes a single change: the subject, one purpose, the new state, the `seq`, the channel and actor, and the effective time. Each event also carries the customer's full profile snapshot (name, NRIC number, date of birth, mobile number, email and postal address), so that consumers never need to call back into Izin to act on an event.

Events use a versioned Avro schema in the Data Hub schema registry with backward-compatible evolution only.

14.4 Relay failure handling

The relay attempts to publish each outbox row up to five times with exponential backoff from 200 ms. A row that still fails is marked `FAILED` and the relay moves on to the next row, so one malformed or oversized event never blocks the stream. `FAILED` rows are listed on the operations dashboard and replayed after review at the weekly operations meeting.

15. Downstream Consumers

Consumer	Owner	How it consumes	What it does with a change
Kempen campaign platform	Group Marketing	Real-time consumer group; also calls the Eligibility API per recipient at send time	Updates audience membership; the send-time check is the final gate
Group Analytics Platform	Group Data Office	Batch consumer, every 6 hours	Excludes withdrawn customers from PRS-OFFERS models and segment exports
Contact centre CRM	Customer Operations	Real-time consumer group	Shows current consent state on the agent desktop; outbound dial lists call the Eligibility API
Rewards platform	Merbau Rewards	Real-time consumer group	Updates newsletter and push audiences
Partner Gateway	Partnerships	Batch consumer, nightly at 01:00 SGT	Builds the nightly partner files of grants and withdrawals for PTN-INS and PTN-CARD and delivers them by SFTP

Consumers apply events in the order received. Kempen and the contact centre CRM treat any non-200 response or timeout from the Eligibility API as "do not contact" (P5), and Kempen records the skipped recipients with the reason so that Marketing can see the effect.

Each partner file contains, per customer whose partner-sharing state changed since the previous file, the name, mobile number, email, Rewards tier and the new state. The partner contract requires the partner to stop using the customer's details for marketing within one business day of a withdrawal appearing in a file.

16. Do Not Call Registry Checks

The DNC Service keeps, for every Singapore telephone number in the marketing base, the most recent DNC Registry result for the voice, text message and fax registers. It submits numbers to the PDPC's DNC Registry through the bulk-check interface and stores each result with the date it was received.

Under the PDPA, the result of a DNC Registry check remains valid for 21 days from receipt, so the DNC Service re-checks every number in the marketing base once every 14 days and serves campaign checks from its cache. The base of about 7.4 million numbers is split into 14 daily cohorts by a hash of the number, so each night's bulk submission is about 530,000 numbers and completes within the overnight window. A number whose result is older than 21 days because its cohort's refresh has not succeeded keeps its last result and is served from it until the next successful refresh, so a registry outage or a rejected bulk file never blocks a campaign. New numbers added to the marketing base are checked within the same day through the single-number interface before they are eligible for any marketing SMS or call.

The Eligibility API combines consent and DNC status for SMS and voice as follows:

Consent state for MKT-SMS / MKT-VOICE on the number	DNC result	Decision
GRANTED, with an evidence_ref	Any	Allowed (clear and unambiguous consent in evidential form)
GRANTED, without an evidence_ref (migrated records, Section 25)	Not registered on the relevant register in the result held	Allowed
GRANTED, without an evidence_ref	Registered, or no result held	Not allowed
WITHDRAWN or no state	Any	Not allowed

A GRANTED state captured through Izin always carries an evidence reference (Sections 10 to 12) and is clear and unambiguous consent in evidential form, so marketing to the number is allowed even if it is listed on the DNC Register. For GRANTED states without one, which come only from the migration, the DNC result decides. Izin never allows marketing on DNC status alone. Email and app push are not covered by the DNC provisions and depend on consent only.

17. Consent Receipts

A consent receipt is a record, given to the customer, of a consent change: what changed, when, through which channel, and the notice version that applied. The Receipt Service creates a receipt for each change request (a request that changes several purposes at once gets one receipt listing all of them).

Each receipt has a receipt number of the form R followed by a ten-digit sequence (for example R0004417302), allocated from a Postgres sequence, for reference in calls and letters. The receipt link carries a separate random 128-bit token (<https://izin.merbau.sg/r/{token}>), stored only as its SHA-256 hash, and the link expires 30 days after issue. Without signing in, the receipt page shows the customer's first name, the masked mobile number or email the receipt was sent to, the receipt number, and the purposes changed with their new states and the time of the change. The current state of every other purpose, and the full contact details, are shown only after the customer signs in with Merbau ID.

Receipts are sent by SMS to the mobile number on the profile, or by email where the customer has no mobile number. Receipts are not themselves marketing and are sent under SVC-NOTICE.

18. Data Model

```
CREATE TABLE purpose (  
  purpose_code    text PRIMARY KEY,  
  basis           text NOT NULL,      -- CONSENT, CONTRACT, LEGAL  
  subject_type    text NOT NULL,      -- CUSTOMER or CONTACT_POINT  
  current_version int  NOT NULL,  
  retired_at      timestampz  
);  
  
CREATE TABLE notice_version (  
  purpose_code    text NOT NULL REFERENCES purpose,  
  purpose_version int  NOT NULL,
```

```

notice_version    text NOT NULL,

material          boolean NOT NULL,

effective_from    timestampz NOT NULL,

text_en text NOT NULL, text_zh text NOT NULL, text_ms text NOT NULL, text_ta text NOT NULL,

PRIMARY KEY (purpose_code, notice_version)

);

```

```

CREATE TABLE contact_point (

    contact_point_id uuid PRIMARY KEY,

    kind              text NOT NULL,          -- MSISDN, EMAIL, APP_INSTALL

    address            text NOT NULL,          -- encrypted column (Section 21)

    address_hash       bytea NOT NULL UNIQUE, -- HMAC-SHA256 lookup key

    mid                uuid,

    linked_at          timestampz

);

```

```

CREATE TABLE consent_event (

    event_id          uuid PRIMARY KEY,

    subject_type       text NOT NULL,

    subject_id         uuid NOT NULL,

    purpose_code       text NOT NULL REFERENCES purpose,

    purpose_version    int  NOT NULL,

    seq                int  NOT NULL,

    state              text NOT NULL,

    channel             text NOT NULL,

    actor_type         text NOT NULL,

    actor_id           text NOT NULL,

    notice_version     text NOT NULL,

    evidence_ref        text,

    idempotency_key    text NOT NULL,

    captured_at        timestampz NOT NULL,

    stored_at          timestampz NOT NULL DEFAULT now(),

    UNIQUE (subject_type, subject_id, purpose_code, seq),

```

```

    UNIQUE (actor_type, idempotency_key)
) PARTITION BY RANGE (stored_at);

CREATE TABLE consent_state (
    subject_type      text NOT NULL,
    subject_id        uuid NOT NULL,
    purpose_code      text NOT NULL,
    state             text NOT NULL,
    seq               int  NOT NULL,
    last_event_id     uuid NOT NULL,
    updated_at        timestampz NOT NULL,
    PRIMARY KEY (subject_type, subject_id, purpose_code)
);

CREATE TABLE receipt (
    receipt_number    text PRIMARY KEY,
    mid               uuid,
    event_ids         uuid[] NOT NULL,
    sent_to           text NOT NULL,
    created_at        timestampz NOT NULL
);

CREATE TABLE outbox (
    outbox_id         bigserial PRIMARY KEY,
    event_id          uuid NOT NULL,
    payload           bytea NOT NULL,
    status            text NOT NULL DEFAULT 'PENDING', -- PENDING, PUBLISHED, FAILED
    attempts          int  NOT NULL DEFAULT 0,
    created_at        timestampz NOT NULL DEFAULT now()
);

```

consent_event is partitioned by month of stored_at. Customer profile fields used in events and receipts (name, NRIC number, date of birth, postal address) are read from the group customer master at write time and are not stored in Izin tables.

19. Retention and Archival

Data	Retention	Mechanism
consent_state	While the subject exists, then 12 months	Deleted 12 months after the customer's last account closes
consent_event	24 months	Monthly partition drop
receipt	24 months	Monthly purge job
outbox (published rows)	7 days	Daily purge job
DNC results	90 days after the result's receipt	Daily purge job
Database backups	35 days	Aurora automated backups

Consent events older than 24 months are deleted by dropping their monthly partition, and the current position for every subject and purpose remains in `consent_state`, so Izin always knows what each customer has agreed to. Dropping a partition is instant and avoids the vacuum load of row-by-row deletes on the largest table.

Contact-centre call recordings are retained by the contact-centre platform under its own policy; signed store forms are retained by the stores document archive.

20. Regulator Audit and Evidence Export

When the Commission investigates a complaint, or a customer disputes a marketing contact, the ODPO must show that Merbau had consent (or a valid DNC result) at the time of the contact. The evidence export produces, for the subjects, purposes and time range requested:

- the consent history: every event with its channel, actor, notice version, evidence reference and time;
- the exact notice text of every notice version referenced;
- the DNC results held for the numbers concerned, with their dates of receipt;
- the receipts issued.

The export is a signed ZIP (detached signature with the ODPO export key in AWS KMS) containing CSV files and a manifest with SHA-256 hashes, generated by an asynchronous job from the ODPO Console. Requests are logged with the requester and the reason. For a single customer the export completes in under a minute; for a whole purpose it runs overnight.

The ODPO's internal target is to answer a Commission request within five business days (NFR-5).

21. Security and Access Control

- **Authentication of callers.** First-party channels call the Consent API with OAuth 2.0 client credentials issued by the group identity provider, plus the end customer's access token for customer-initiated changes. Agent and staff changes carry the agent's identity from the CRM or POS session. Partners use mutual TLS and signed requests (Section 12).
 - **Authorisation.** Each channel client is allowed only the actor types it may claim; the web client cannot submit a change as AGENT, and the contact-centre client cannot submit as CUSTOMER.
 - **Encryption.** TLS 1.2 or higher in transit. Aurora storage encryption with a customer managed KMS key. Contact point addresses are additionally encrypted at column level with a data key from KMS, and looked up by an HMAC of the normalised address.
 - **Staff access.** ODPO Console users sign in through corporate SSO with phishing-resistant MFA. Every view of a customer record and every export is written to the access log, which is shipped to the group security log store and retained for seven years.
 - **Database access.** No human has standing access to the production database; break-glass access requires a second approver and is time-limited to four hours.
-

22. Data Residency and Partner Data Sharing

NFR-7 places every Izin data store in Singapore: the Aurora cluster, the MSK cluster, backups, logs and the evidence

export bucket are all in ap-southeast-1, and Izin has no other region.

Seri Assurance receives its nightly partner file on its SFTP server in Kuala Lumpur, where its marketing and contact-centre systems run. Lintang Bank receives its file on an SFTP server in its Singapore data centre. Residency is fully met by this placement: every Izin data store is in ap-southeast-1, and partner processing after the nightly file is delivered is the partner's own responsibility.

Partners are registered in the ODPO Console with their purposes, SFTP endpoints, PGP keys and contact persons. A partner can be suspended in the console, which stops its file and rejects its Partner Consent API calls at once.

23. Resilience and Disaster Recovery

23.1 Within the region

The Consent Store is an Aurora PostgreSQL cluster with a writer and two readers in three availability zones. Aurora writes six copies of each change across three AZs and acknowledges a commit once four are durable, so the loss of one AZ loses no acknowledged change (NFR-4); failover to a reader takes about 30 seconds, during which the Consent API returns 503 and channels retry with the same idempotency key. The MSK cluster has three brokers across three AZs, replication factor 3, `min.insync.replicas 2` and `producer acks=all`, so a published event survives the loss of an AZ. EKS runs every Izin service with at least three replicas spread across AZs.

23.2 Region loss

Izin has no second region, by decision DEC-04: AWS has one region in Singapore, and NFR-7 rules out placing a replica elsewhere. Aurora snapshots are copied every four hours to a backup vault in a separate AWS account in ap-southeast-1 with vault lock, so that a compromise of the production account cannot destroy them. In the event of a full loss of ap-southeast-1, Izin is rebuilt from the latest snapshot when the region returns; the business has accepted an RTO of 24 hours and an RPO of four hours for that event, and recorded it in the risk register (RR-118).

23.3 Behaviour during an outage

While the Consent API is unavailable, channels show the customer that preferences cannot be changed right now and do not queue changes, except the offline store tablets (Section 11). While the Eligibility API is unavailable, Kempen and the contact centre stop marketing contacts (P5); service messages, which do not depend on Izin, continue.

24. Latency and Capacity Budget

24.1 Consent API latency (p99, single change)

Step	Budget
API gateway, TLS termination and token validation	25 ms
Request validation against the cached purpose catalogue	5 ms
Database transaction (lock state row, insert event, update state, insert outbox)	60 ms
Customer master read for the profile snapshot	40 ms
Receipt number allocation and receipt row	15 ms
Response	5 ms
Total	150 ms (NFR-1: 300 ms)

24.2 Eligibility API capacity

The heaviest load on Izin comes from campaign sends, because Kempen checks every recipient with the Eligibility API at send time. The largest campaign, the monthly Rewards newsletter, goes to 3.0 million recipients in a one-hour send window, which is about 833 requests per second. The Eligibility API is provisioned for 1,000 requests per second at p99 50 ms (NFR-8), and Kempen paces each campaign to at most 800 requests per second, so a newsletter of 3.0 million recipients completes in about 63 minutes; requests above the provisioned rate are rejected with 429 by the API

gateway's rate limit to protect the Consent Store writer.

24.3 Storage

Table	Basis	Size
consent_state	5.2 million customers × 7 consent purposes × 180 bytes	about 6.6 GB
consent_event	140,000 events a day × 24 months × 600 bytes	about 61 GB
contact_point	12 million contact points × 300 bytes	about 3.6 GB
receipt	140,000 receipts a day × 24 months × 450 bytes	about 46 GB

The Aurora cluster uses db.r7g.2xlarge instances; the working set of consent_state and the indexes fits in memory.

25. Migration from Legacy Systems

The legacy sources are the telco CRM (Arus), the Rewards platform (Mata) and the scanned store sign-up forms. Migration runs once per business unit, before that unit's channels switch to Izin.

Legacy source	Legacy field	Izin mapping
Arus	sms_optout = Y	MKT-SMS WITHDRAWN on the line's number
Arus	call_optout = Y	MKT-VOICE WITHDRAWN on the line's number
Arus	email_optout = Y	MKT-EMAIL WITHDRAWN
Arus	sms_optin = Y or call_optin = Y (roadshow sign-ups 2016 to 2019; paper forms not retained)	MKT-SMS or MKT-VOICE GRANTED on the line's number, no evidence_ref
Mata	newsletter = Y with sign-up date and channel	MKT-EMAIL GRANTED, evidence_ref to the Mata sign-up record
Store forms	Ticked marketing box, signed	Purposes ticked GRANTED, evidence_ref to the form scan

Merbau Mobile's 2019 privacy notice told all subscribers that Merbau would market its products by SMS, call, email and push unless they opted out. Customers with no recorded preference in the legacy systems are migrated with no event for the marketing purposes, so the Eligibility API treats those purposes as not granted (Section 10). They are invited to set their preferences through a card in the Merbau app and a notice with their monthly bill, both of which link to the preference centre. The marketing base reachable on the first day is therefore about 1.9 million customers, not the 3.4 million reachable from the legacy flags; Group Marketing has accepted this.

Every migrated event has channel = MIGRATION, actor_type = SYSTEM and the captured_at of the legacy record where one exists, else the migration time. The migration is idempotent: it uses the legacy record key as the idempotency key, so it can be re-run after a partial failure.

26. Confirmed Decisions

ID	Decision	Rationale
DEC-01	Aurora PostgreSQL 16, db.r7g.2xlarge, writer and two readers, three AZs	Transactional writes of event, state and outbox; familiar to the team
DEC-02	Amazon MSK (Merbau Data Hub cluster), topic consent_changes, 24 partitions, compacted, keyed by subject and purpose	Shared platform, bootstrap from the topic
DEC-03	Transactional outbox with a single active relay	No dual write
DEC-04	Single region ap-southeast-1; snapshot copies to a separate account; region-loss RTO 24 h, RPO 4 h accepted (RR-118)	NFR-7; only one AWS region in Singapore
DEC-05	MKT-SMS and MKT-VOICE held per contact point; other purposes per customer	DNC provisions apply per number
DEC-06	DNC results cached and refreshed in 14 daily cohorts; a result awaiting refresh is served until the next successful refresh	21-day validity; registry load
DEC-07	Eligibility API reads consent state from the writer endpoint	Read-your-writes for withdrawals
DEC-08	Receipts by SMS, or email where no mobile number exists	Every customer has at least one

ID	Decision	Rationale
DEC-09	Seri Assurance captures Merbau consent (PTN-INS and MKT-EMAIL) in its own app through the Partner Consent API from Phase 4	Partner programme launch in Q2 2027
DEC-10	Partner files nightly by SFTP with PGP encryption	Partner capabilities
DEC-11	Legacy preferences migrated per Section 25; no consent is created for customers with no recorded preference	Only recorded choices carry over
DEC-12	Consent events retained 24 months	Storage and vacuum load

27. Pending Backlog

Items confirmed as in scope but not yet fully designed:

ID	Item	Status
PB-01	Chinese, Malay and Tamil notice translations for PTN-INS and PTN-CARD	With the translation vendor
PB-02	Kempen dashboard of recipients skipped by the Eligibility API, by reason	Kempen team scheduled for Q1 2027
PB-03	Data-sharing agreement with Seri Assurance, including the legal opinion on whether consent captured by Seri for Merbau purposes is valid consent given to Merbau	Pending with Group Legal; opinion requested 2026-08
PB-04	Customer-facing receipt page design and accessibility review	Design team
PB-05	Retirement plan for the Arus and Mata opt-out columns after migration	Business units
PB-06	ODPO Console role model beyond Admin and Viewer	ODPO

28. Validation and Acceptance Criteria

Each requirement from Section 2 is validated by a specific method with a concrete pass or fail criterion. This table is the basis for the test plan in Build Phase 6.

28.1 Functional requirements

ID	Validation method	Acceptance criteria
FR-1	API contract tests per channel client	Every channel can grant and withdraw every purpose it is registered for; requests for other purposes return 403.
FR-2	UI review and API negative tests	No sign-up or preference screen has a pre-selected marketing toggle; the API rejects a grant without a current notice version.
FR-3	Event completeness check	For 1,000 changes across all channels, every event has channel, actor, notice version, time and evidence reference populated.
FR-4	Channel walkthrough	In every channel, withdrawing a purpose takes no more steps than granting it.
FR-5	Outbox and relay test	Every committed change appears on consent . changes exactly once (by event_id) after a relay pod is killed mid-batch.
FR-6	Eligibility decision table test	For every combination in Section 16, the API returns the documented decision.
FR-7	DNC test with the registry test environment	Numbers registered in the test registry are refused without evidential consent and allowed with it.
FR-8	Preference centre end-to-end test	Every purpose is listed with its state and notice text; a change made in the app is shown on the web after reload.
FR-9	Receipt test	For 500 changes across every channel, each produces exactly one receipt within five minutes, sent to the mobile number or, for profiles with no mobile number, the email; the receipt link opens the receipt without sign-in, shows only the fields listed in Section 17, and stops working after 30 days.
FR-10	Partner API conformance test	A registered partner can submit only its listed purposes; an unregistered certificate is refused.
FR-11	Evidence export test	For 50 seeded customers, the export contains every event, the notice texts and the DNC results, and the

ID	Validation method	Acceptance criteria
		signature verifies.
FR-12	Keyword and IVR test	A STOP reply and the IVR opt-out each produce a withdrawal on the number within one minute.
FR-13	Migration reconciliation	Counts of migrated grants and withdrawals per source match the legacy extracts.
FR-14	Console test	ODPO users can create a purpose version and a notice version; viewers cannot.

28.2 Non-functional requirements

ID	Validation method	Acceptance criteria
NFR-1	Load test at 120 changes per second	p99 Consent API latency of 300 ms or less over 30 minutes.
NFR-2	Propagation test in pre-production at design-target load	Over 24 hours, record 1,000 withdrawals spread across every channel (app, web, contact centre, store, partner API, STOP reply and IVR), a third of them followed within an hour by another change for the same customer; restart the relay and each consumer once during the run. Every withdrawal is applied in Kempen, the Group Analytics Platform, the contact centre CRM and the Rewards platform within 24 hours of being recorded, and every partner-purpose withdrawal appears in the next nightly partner file.
NFR-3	Synthetic probes	Monthly availability of 99.95% or more measured by probes every 30 seconds.
NFR-4	AZ failure game day	After a forced writer failover under load, every change acknowledged to the load generator is present in consent_event.
NFR-5	Evidence drill	The ODPO produces a full evidence export for 10 named customers within five business days.
NFR-6	Security review and penetration test	No high or critical findings open at go-live; access log entries present for every console view in the test.
NFR-7	Infrastructure review	Every Izin resource in the IaC is in ap-southeast-1.
NFR-8	Load test of the Eligibility API at 1,000 requests per second, with a concurrent consent-change load of 120 per second	p99 latency of 50 ms or less over 30 minutes, with no 429 responses below 1,000 requests per second.
NFR-9	DNC compliance audit	For a sample of 1,000 marketing SMS from the pilot, each number had evidential consent or a valid DNC result at send time.

29. Implementation Readiness Assessment

Could an engineering team build each component from this document without further design decisions?

Component	Ready?	What remains to decide
Consent API and record model	Ready	Sections 9, 18.
Preference centre (web and app)	Ready	Section 10; receipt page design in PB-04.
Contact centre and store capture	Ready	Section 11.
Partner Consent API	Ready	Section 12; Seri go-live per DEC-09.
Outbox Relay and event bus	Ready	Section 14.
Eligibility API and DNC Service	Ready	Section 16.
Receipt Service	Mostly ready	Page design (PB-04).
Partner Gateway	Ready	Section 15.
Retention jobs	Ready	Section 19.
Evidence export	Ready	Section 20.
Migration	Ready	Section 25.
Kempen integration	Mostly ready	Section 15; skipped-recipient dashboard (PB-02).

Overall conclusion

The consent core, propagation and DNC handling are specified to implementation level. The open items (translations, the skipped-recipient dashboard, the receipt page design and the console role model) do not block the first cohort.

30. Build Phases

#	Phase	Depends on open design items?
1	Foundations: EKS namespace, Aurora cluster, topic and schema registry, IaC, CI/CD, observability	No, ready
2	Consent core: Consent API, record model, outbox and relay, preference centre for Merbau Mobile, receipts	Partially, receipt page design (PB-04)
3	Eligibility API, DNC Service, Kempen and contact centre CRM integration; migration of Arus	Partially, skipped-recipient dashboard (PB-02)
4	Stores, Rewards and Fibre channels; migration of Mata and store forms; Partner Consent API and Partner Gateway with Seri Assurance and Lintang Bank	No, ready
5	Evidence export, ODPO Console, retention jobs	No, ready
6	Hardening: load, failure and DR game days; penetration test; Section 28 test plan	Follows Section 28
The first cohort (Merbau Mobile in web and app) goes live after Phase 3; the other business units follow at six-week intervals. No implementation has begun.		